

# Web Security

Module VII

# What is Web Security?

- Web Security, also known as "Cyber security" involves **protecting that information** by **preventing, detecting, and responding** to attacks



# Web Security Considerations

- Web security is fundamentally a client/server application running over the Internet and TCP/IP intranets
  - The WEB is very visible
  - Complex software hide many security flaws
  - Web servers are easy to configure and manage
  - Users are not aware of the risks

# Web Security Threats

- Security threats faced in using the web
  1. **Active attacks** – include impersonating another user, altering messages in transit between client and server, and altering information on a Web site
  2. **Passive attacks** – include eavesdropping on network traffic between browser and server and gaining access to information on a Web site that is supposed to be restricted
  3. Classify Web security threats is in terms of the **location of the threat**:
    - Web server, Web browser, and network traffic between browser and server

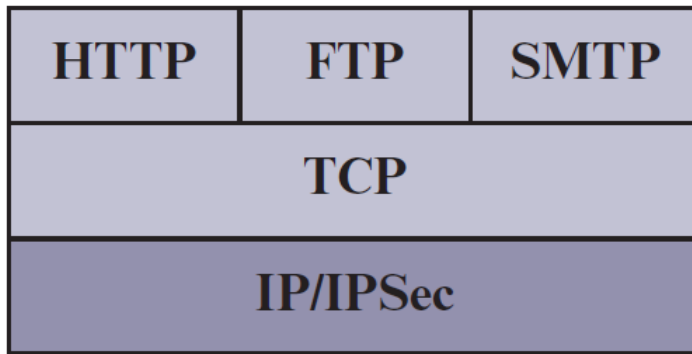
# A Comparison of Threats on the Web

|                          | Threats                                                                                                                                                                                                                                         | Consequences                                                                                                                                       | Countermeasures          |
|--------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------|
| <b>Integrity</b>         | <ul style="list-style-type: none"><li>• Modification of user data</li><li>• Trojan horse browser</li><li>• Modification of memory</li><li>• Modification of message traffic in transit</li></ul>                                                | <ul style="list-style-type: none"><li>• Loss of information</li><li>• Compromise of machine</li><li>• Vulnerability to all other threats</li></ul> | Cryptographic checksums  |
| <b>Confidentiality</b>   | <ul style="list-style-type: none"><li>• Eavesdropping on the net</li><li>• Theft of info from server</li><li>• Theft of data from client</li><li>• Info about network configuration</li><li>• Info about which client talks to server</li></ul> | <ul style="list-style-type: none"><li>• Loss of information</li><li>• Loss of privacy</li></ul>                                                    | Encryption, Web proxies  |
| <b>Denial of Service</b> | <ul style="list-style-type: none"><li>• Killing of user threads</li><li>• Flooding machine with bogus requests</li><li>• Filling up disk or memory</li><li>• Isolating machine by DNS attacks</li></ul>                                         | <ul style="list-style-type: none"><li>• Disruptive</li><li>• Annoying</li><li>• Prevent user from getting work done</li></ul>                      | Difficult to prevent     |
| <b>Authentication</b>    | <ul style="list-style-type: none"><li>• Impersonation of legitimate users</li><li>• Data forgery</li></ul>                                                                                                                                      | <ul style="list-style-type: none"><li>• Misrepresentation of user</li><li>• Belief that false information is valid</li></ul>                       | Cryptographic techniques |

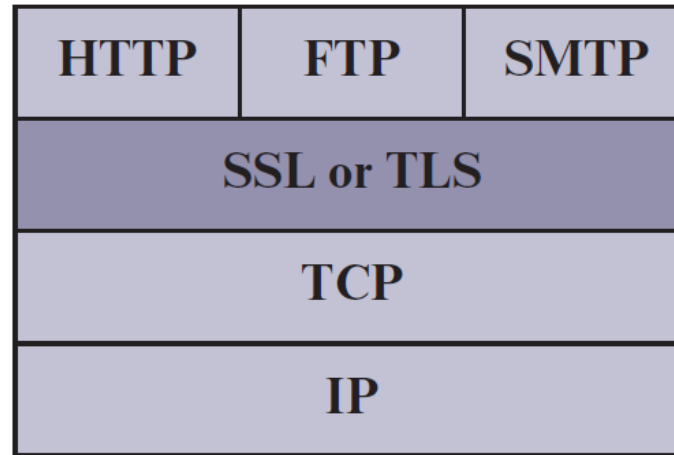
# Web Traffic Security Approaches

- A number of approaches to providing web security are possible
- The various approaches that have been considered are similar in the services they provide and, to some extent, in the mechanisms that they use, but they differ with respect to their scope of applicability and their relative location within the TCP/IP protocol stack

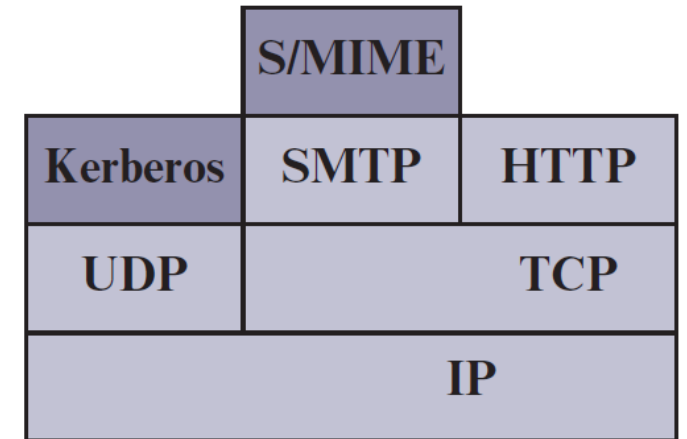
# Relative Location of Security Facilities in the TCP/IP Protocol Stack



(a) Network level



(b) Transport level



(c) Application level

# Secure Electronic Transaction (SET) Protocol & Trusted Systems



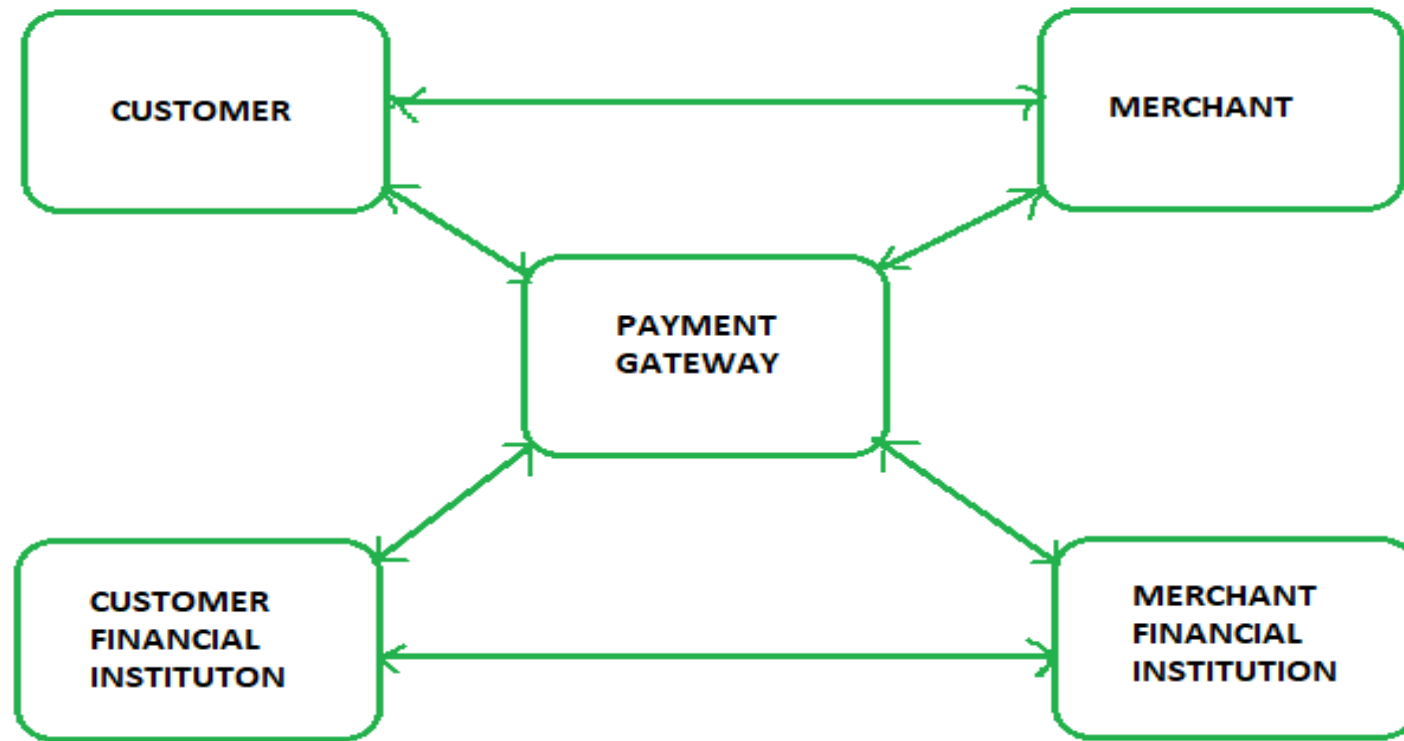
# Secure Electronic Transaction (SET) Protocol

- **Secure Electronic Transaction** or SET is a system that ensures the security and integrity of electronic transactions done using credit cards in a scenario
- SET is not some system that enables payment but it is a security protocol applied to those payments
- It uses different encryption and hashing techniques to secure payments over the internet done through credit cards
- The SET protocol was supported in development by major organizations like Visa, Mastercard, and Microsoft which provided its Secure Transaction Technology (STT), and Netscape which provided the technology of Secure Socket Layer (SSL)

# Secure Electronic Transaction (SET) Protocol – cont...

- SET protocol restricts the revealing of credit card details to merchants thus keeping hackers and thieves at bay
- The SET protocol includes Certification Authorities for making use of standard Digital Certificates like X.509 Certificate
- Before discussing SET further, let's see a general scenario of electronic transactions, which includes client, payment gateway, client financial institution, merchant, and merchant financial institution

# Example



# Requirements in SET

- It has to provide mutual authentication i.e., customer (or cardholder) authentication by confirming if the customer is an intended user or not, and merchant authentication
- It has to keep the PI (Payment Information) and OI (Order Information) confidential by appropriate encryptions
- It has to be resistive against message modifications i.e., no changes should be allowed in the content being transmitted
- SET also needs to provide interoperability and make use of the best security mechanisms

# Participants in SET

- **Cardholder** – customer
- **Issuer** – customer financial institution
- **Merchant**
- **Acquirer** – Merchant financial
- **Certificate authority** – Authority that follows certain standards and issues certificates(like X.509V3) to all other participants

# SET functionalities

- **Provide Authentication**

- **Merchant Authentication** – To prevent theft, SET allows customers to check previous relationships between merchants and financial institutions. Standard X.509V3 certificates are used for this verification
- **Customer / Cardholder Authentication** – SET checks if the use of a credit card is done by an authorized user or not using X.509V3 certificates

- **Provide Message Confidentiality**: Confidentiality refers to preventing unintended people from reading the message being transferred. SET implements confidentiality by using encryption techniques. Traditionally DES is used for encryption purposes

- **Provide Message Integrity**: SET doesn't allow message modification with the help of signatures. Messages are protected against unauthorized modification using RSA digital signatures with SHA-1 and some using HMAC with SHA-1

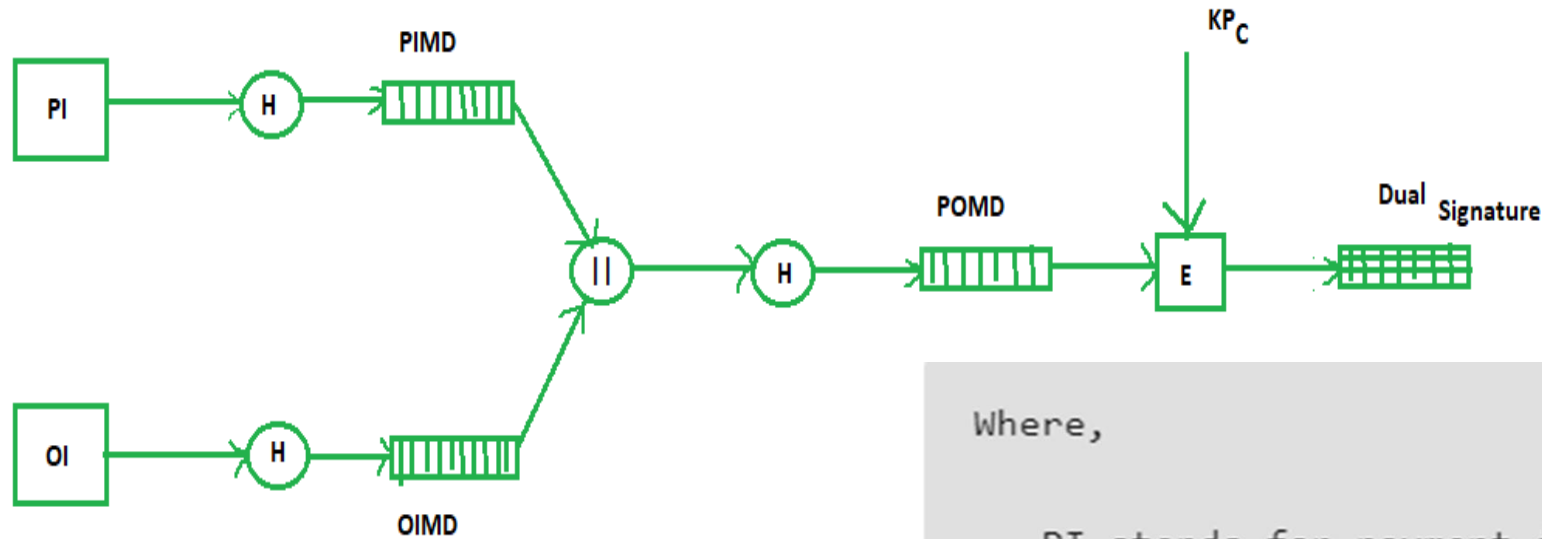
# Cont...

- **Dual Signature:** The dual signature is a concept introduced with SET, which aims **at connecting two information pieces** meant for two different receivers :
- **Order Information (OI) for merchant**

## **Payment Information (PI) for bank**

- You might think sending them separately is an easy and more secure way, but **sending them in a connected form resolves any future dispute possible.**

# Generation of dual signature



Where,

PI stands for payment information

OI stands for order information

PIMD stands for Payment Information Message Digest

OIMD stands for Order Information Message Digest

POMD stands for Payment Order Message Digest

H stands for Hashing

E stands for public key encryption

KPc is customer's private key

|| stands for append operation

Dual signature,  $DS = E(KPc, [H(H(PI)||H(OI))])$



# Trusted Systems in Network Security

- **Cyber Safety** is the branch of technology that educates users about the security and safety of the technology they use in their day-to day lives
- Users of technology must be aware of the best practices when they use the cloud
- Any threat to security is directly making the computer system susceptible to the threat and risking safety of the system
- Security of the network and technology is thus very essential for protection from vulnerable risks
- One such significant role in security is played by Trusted Systems.
  - **Trusted Systems** are special systems designed to serve the purpose of providing security
- Safety is ensured by trusted system in a manner by protecting the system against malicious software's and third-party intruders

# Cont...

- Trusted system allow only verified users to access the computer system
- Trusted system are responsible for providing security at different levels and based on different parameters

# Different Level of Security

- **Multilevel Security**

- Ensures that security is maintained at different levels of the computer system
- It ensures that the information is prevented from being at risk
- The different security levels of computer systems are:
  1. Top Secret Level
  2. Secret Level
  3. Confidential Level
  4. Unclassified Level

- **Data Access Control**

- Provides additional security to the verified process of log-in
- It helps in setting permissions for different users, giving them limited access and restricting any additional accesses granted

# Data Access Control

1. **Access Matrix:** They are composed of three parts
  - Subject
  - Object
  - Access right
2. **Access Control List:** They are composed of different entries of objects depicting user access and the level of access granted (public or private).  
Access control list demonstrate column-wise split
3. **Capability List:** They are composed of authorized users and the granted operations for them. Users can have multiple capability tickets. Capability list demonstrate row-wise split

# Importance of Trusted System

- **Identity Verification:** Trusted systems ensure that only verified users are given access. The verification process takes place that each user is identified uniquely
- **Safety Maintained:** Trusted system ensures that safety is maintained by preventing direct access to confidential information
- **Limiting Access:** Permissions and access that are absolutely necessary are granted for users. Unwanted rules and permissions are avoided
- **Preventing Malicious Activities:** Trusted systems have a mechanism in place to detect and prevent malicious activities such as hacking attempts and unauthorized access
- **Ensuring Compliance:** Trusted systems help organizations to comply with various regulations and standards such as HIPAA, PCI-DSS, and SOX by providing a secure environment for sensitive information

# Examples of Trusted Systems

- **Windows BitLocker**

- Windows BitLocker is a trusted system that provides encryption for the entire hard drive
- It prevents unauthorized access to the data stored on the hard drive by requiring a password or a smart card to unlock the drive

- **TPM (Trusted Platform Module)**

- A TPM is a hardware-based security chip that is built into a computer
- It provides secure storage for encryption keys and can be used to verify the integrity of the system at boot time

- **Trusted Boot**

- Trusted Boot is a feature that ensures that the system is running a trusted version of the operating system
- It works by verifying the integrity of the boot process and ensuring that only signed and trusted software is executed